

CO2 - ASS 31) Footprinting tools - Conducting Competitive Intelligence

Scenario:- A Cybersecurity consultant has been assigned to perform a passive security assessment for ABC technologies. The consultant must collect publicly available information without directly interacting with the company's servers.

Answer:-

1. Identifying Domain Registration Details

Tools used:- WHOIS

Command:-

whois abctechnologies.com

Information obtained:-

- Domain name
- Registrar name
- Registration and expiry dates
- Name servers
- Domain status.

2. Identifying Employee Email Address

Tools used:- theHarvester

Command:- theHarvester -d abctechnologies.com -b all

Information obtained:-

- Employee email address
- Employee names
- public hosts
- Associated domains

3) Identifying Technology Stack

Tool used :- Wappalizer or Builtwith

Information obtained :-

→ Web server (Apache, Nginx, IIS)

→ programming language

→ CMS

→ javascript frameworks

→ CDN

→ Hosting provider

4) Identifying publicly exposed subdomains

Tool used :- Comrad :- sublist3r -d abctechnologies.com

→ Sublist3r

→ Amass

→ Crt-sh

Information obtained :-

→ mail.abctechnologies.com

→ vpn.abctechnologies.com

→ dev.abctechnologies.com

→ test.abctechnologies.com

→ api.abctechnologies.com

2) DNS Zone Transfers

Scenario :- A security analyst suspects that the DNS server is misconfigured and may allow unauthorized DNS zone transfers.

Answers :-

Tool used :-

dig :- dig AXFR example.com @ns1.example.com

Information Retrieved:-

Internal Hosts:-

dev. example.com

test. example.com

server01. example.com

Mail Servers:-

ex:-

mail. example.com

mx Record

Purpose:-

- Identifies email servers
- Useful for evaluating email security

Subdomains

ex:- vpn. example.com

ftp. example.com

Purpose:-

- Identifies public services
- Reveals remote access points.

3) Social Engineering Attacks and Countermeasures:-

Scenario:- Employee receives an email claiming to be from the IT department asking them to verify their login credentials using a provided link.

Answer:-

Indicators of the Attack:-

- claims to be from the IT department.
- Creates urgency.
- Requests login credentials.
- Includes a suspicious hyperlink.

Countermeasures:-

1. Verify the Sender's Email Address:-

- check whether the sender's email matches the official company domain.
- Be cautious of slight spelling differences.

2. Do Not Click Suspicious Links:-

- Hover over the link before clicking.
- Verify the destination URL.

3. Access the Website Manually:-

- Instead of clicking the email link, open the organization's official website directly through the browser.

4. Contact the IT Department

- Verify the request using official communication channels before responding.

5. Never share credentials

- organizations do not ask users to provide passwords through email's.

6. Report the Email:-

- use the organization's phishing reporting mechanism or notify the IT Security team.